

Track 1 — EarthIsMine on BAYBENCH: Static Detector Results

20 September 2026

Status: results paper (paper-styled snapshot; not the spec)
Date: 2026-09-20
Team: EarthIsMine (detector and noexit)
Scope: TRUST404 Track 1, *Smart Contract Threat Detection* — offline .sol directory in; BAYBENCH scores Benign / Malicious / Uncertain
Numbers: reports/{detector,noexit,baseline_slither,baseline_keyword}/report.json only. Nothing here is invented.
Taxonomy: [track1-malice-patterns.md](#)
Ledger: [earthismine-baybench-results.md](#)

This note freezes one run of the EarthIsMine detector and the teammate tool `noexit` on BAYBENCH after Phase 5 (decisive mode). Parent Acceptance stays in `docs/specs/baybench.md` and `docs/specs/detector.md`.

0. What the track is grading

Two surfaces share the same three words and do not score them the same way.

BAYBENCH (this repository) is an offline harness. A tool reads staged .sol files and writes `results.json`. Verdicts are Benign | Malicious | Uncertain. Uncertain still receives a partial score (0.5 / 0.75). After Phase 5, our Uncertain is compile failure, timeout, analysis error, or `external_dependency` — not “we noticed a medium-severity shape.”

TRUST404 Track 1 official grades a nonempty JSON *array* on stdout, uppercase MALICIOUS | BENIGN | UNCERTAIN, basename `file`, network off. Official UNCERTAIN is **abstain**: +0, no -1, no credit. BENIGN is SAFE. A wrong call is -1 (floor 0). Emitting BAYBENCH `results.json` on stdout fails the submission. The track page asks for risk from **logic flow and permission structure, not keyword matching**, and for reasoning about 비정상적 권한 이전 and 은닉된 자산 인출 경로. Those phrases are the same categories the literature survey names *Ownership Fraud* and *Leaking Token / Funds Manipulation*. The problem class is **scam-contract detection**, not vulnerability detection.

The organizers’ public five (`challenge_public/`, ingested here as Tier 0) are not the grade set. The private set is variants and lookalikes. This paper does not tune on filenames.

1. Problem framing

The literature survey for this build ([track1-malice-patterns.md](#)) reduces every strong static tool to one structural question:

*Is there a **privileged writer** to a **state variable** that sits on the user's **transfer / exit path**, or that touches **balances** directly?*

EarthIsMine's `detector` is a name-agnostic implementation of that triple on Slither IR: privilege, writable state, and whether that state gates transfer, balances, or an ETH/token exit. It is offline and deterministic. Findings are a list. The verdict is one value.

`noexit` is the teammate tool (T404 16fac68, 52 rule ids). It sits on the same grader. This repository registers it only through `baybench/tools.yaml`.

Baselines on the same 859 files: **Slither native** (any High → Malicious) and **keyword** (name regex → Malicious). Aderyn and Mythril were not installed and are not in the table.

2. How the detector decides

Phase 5 is **decisive mode** (ratified with the spec on 2026-09-20). A finding is not a verdict.

1. Every catalog rule may emit a finding (rule id, family A–G, severity, contract, function, lines, reasoning). Dedup is only (rule_id, function, lines, severity).
2. Bounding discriminators (constant_cap, fee_cap, ungate_exists, foreign_only, two_step_handoff, and the rest of the bounding class) set that finding to INFO. Governance notes (managed_role, issuer_token) annotate and leave HIGH. Concealment rules stay HIGH.
3. A **counting** finding is HIGH-base, or a decisive MED (HONEYPOT_LEGACY, PONZI_SHAPE, STRUCT_PROXY_EOA_ADMIN, OWN_TX_ORIGIN, EXIT_TIME_GATE with no_expiry), or an exploit-shape Slither overlay, with no bounding discriminator.
4. Verdict: any counting finding → Malicious; else STRUCT_EXTERNAL_GATE → Uncertain(external_dependency); else Benign. Compile fail / timeout / analysis error → Uncertain.

Retired: the MED verdict class (med_findings), two-family escalation, and slither_high as a verdict reason. FEE_ADDR_MUTABLE is INFO. PRIV_ROLE and evidence-only overlay do not escalate.

That last-mile choice is the difference between “we found a shape” and a Track 1 last word. Official Uncertain is almost SAFE (abstain). Ours is no longer a parking lot for every MED honeypot.

3. What BAYBENCH measures

A tool reads staged `.sol` and writes `results.json`. The headline score is **not** case-weighted. It is the mean of per-tier means with weights T0=1, T1=2, T2=1, T3=2. Tier 0 is a gate line `tier0_exact: k/5` as well as a weighted term (weight 1.0 so five samples are not 44% of the score).

Tier	n	What it is
0	5	Organizers' public samples (challenge_public/). Gate tier0_exact
1	67	Written malicious and benign twins, one pair per catalog rule, plus harness fixtures
2	779	Paper fixtures: Pied-Piper (injected and on-chain), CRPWarner, HoneyBadger Table 5. One paper category maps to one family
3	8	Risky-looking contracts (OZ, USDC, Bancor, and similar). USDC, Bancor, and MiniMe/Lido are preferred Malicious (accepted Benign). The other five must stay Benign with zero HIGH

Family recall (malicious cases that have `expected_families`): share with at least one finding whose family is in that set. Any-hit, not all-hit. Expected {A,B,C} and a fire of only C is an overall hit; per-family charts then show C hit, A miss, B miss. Verdict score is a separate number.

HIGH False Positive: Benign-preferred cases with any HIGH finding, over Benign-preferred cases. Uncertain on a lookalike does not count.

Most labels are single-tag. 548 of 551 labeled-malice cases have exactly one expected family. Tier 2 ingest still maps one paper category to one letter; HoneyBadger is all F. The three exceptions are the Tier 3 files now tagged Malicious (Bancor, Lido, USDC). Family recall on this mix is therefore almost “share of required families hit.” It is not “we listed every pattern present in the source.”

Charts keep the axis as Tier 0 / 1 / 2 / 3. This paper does not invent a second proper name for each tier.

4. Headline results

Local rerun 2026-09-20, `--no-docker --repeat 1`, all tiers, n=859. Detector wall 304.8 s. `noexit` wall 19.6 s. Slither wall 66.5 s. Keyword 0.38 s. Detector weighted **matches** the Phase 5 Docker all-tier report (799361b, `--repeat 2`, determinism pass). This local run is `--repeat 1`, so the determinism cell is unmarked.

Tool	Weighted	Mean verdict	Family recall	HIGH-FP	Compile fail	Tier 0 exact
detector	0.9714	0.9008	0.9201	0.0	190	5/5
noexit (16fac68)	0.9194	0.7989	0.6933	0.0238	0	5/5
Slither	0.6298	0.6612	0.0036	0.119	0	3/5
keyword	0.4269	0.3513	0.1906	0.4286	0	3/5

A previous snapshot (pre-Phase-5 labels, n=853, no Tier 0) had detector 0.8709 / `noexit` 890405f 0.7745 / Slither 0.5990 / keyword 0.3978. That row is a different mix, a different `decide()`, and different weights. It is not an A/B of the same grader.

By tier (mean verdict)

Tool	Tier 0 (5)	Tier 1 (67)	Tier 2 (779)	Tier 3 (8)
detector	1.0	1.0	0.8909	0.9688
noexit (16fac68)	1.0	0.8955	0.7875	0.9688
Slither	0.6	0.5672	0.6694	0.6875
keyword	0.6	0.597	0.3299	0.2188

Detector Tier 1 rule recall on the written twins is 1.0. Detector HIGH False Positive is 0.0 on 42 preferred-Benign files.

Detector family recall (labeled malice): A Exit gating 0.981 (n=105), B Balance tamper 0.8785 (n=107), C Leak 1.0 (n=8), D Hidden owner 1.0 (n=4), E Structure 1.0 (n=5), F Honeygot / drain 0.9105 (n=324), G Ponzi 1.0 (n=1).

Detector family mean verdict: A 0.9048, B 0.965, C 1.0, D 1.0, E 0.95, F 0.9923, G 1.0.

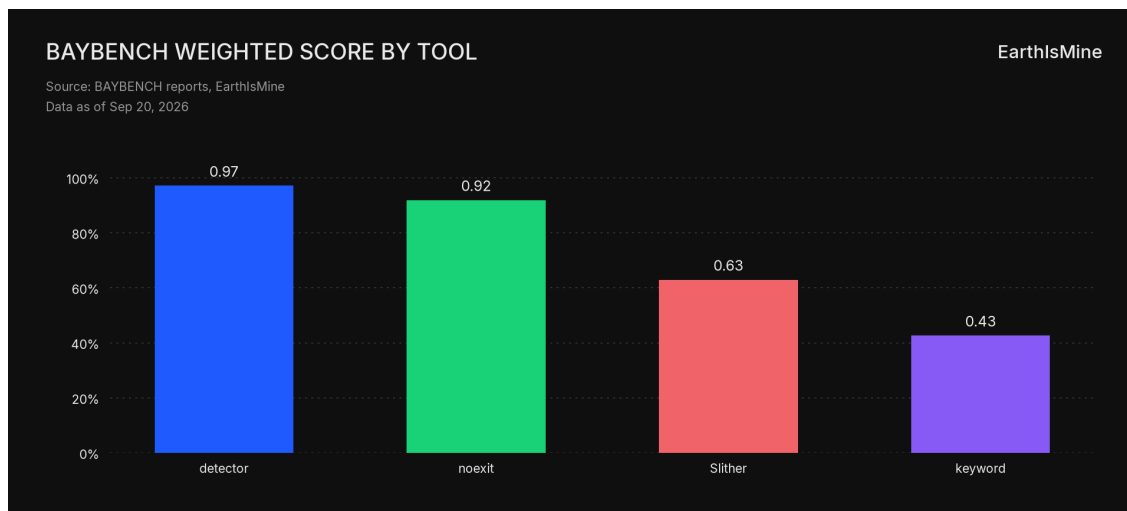


Figure 1: BAYBENCH weighted score by tool. Detector 0.9714; noexit 0.9194; Slither 0.6298; keyword 0.4269.

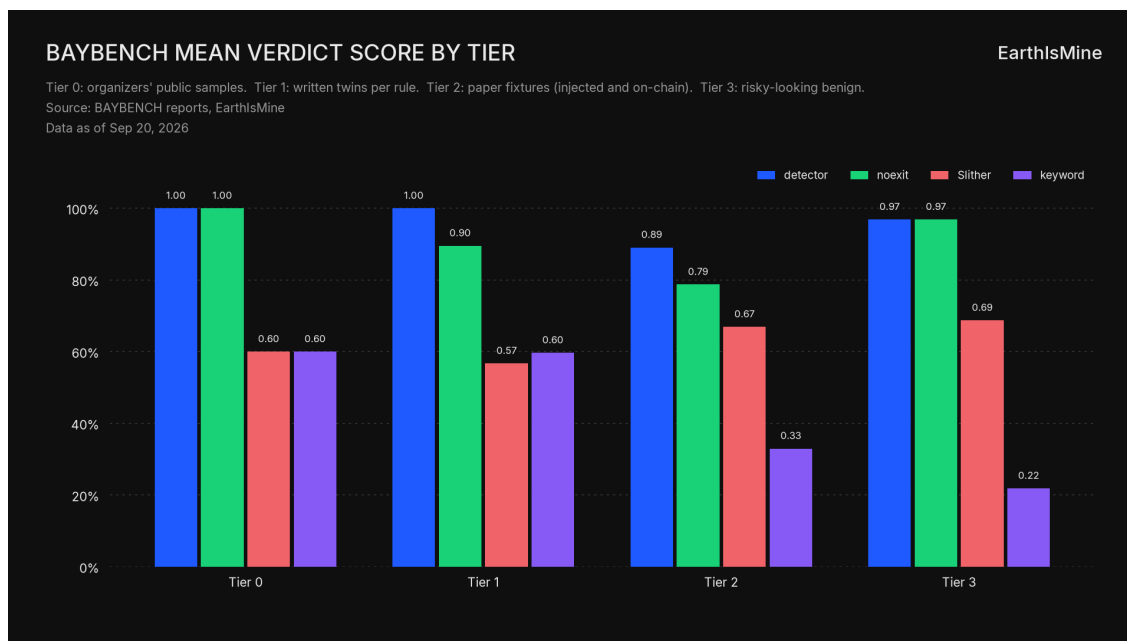


Figure 2: Mean verdict score by tier. Detector is 1.0 / 1.0 / 0.8909 / 0.9688 on Tiers 0–3.

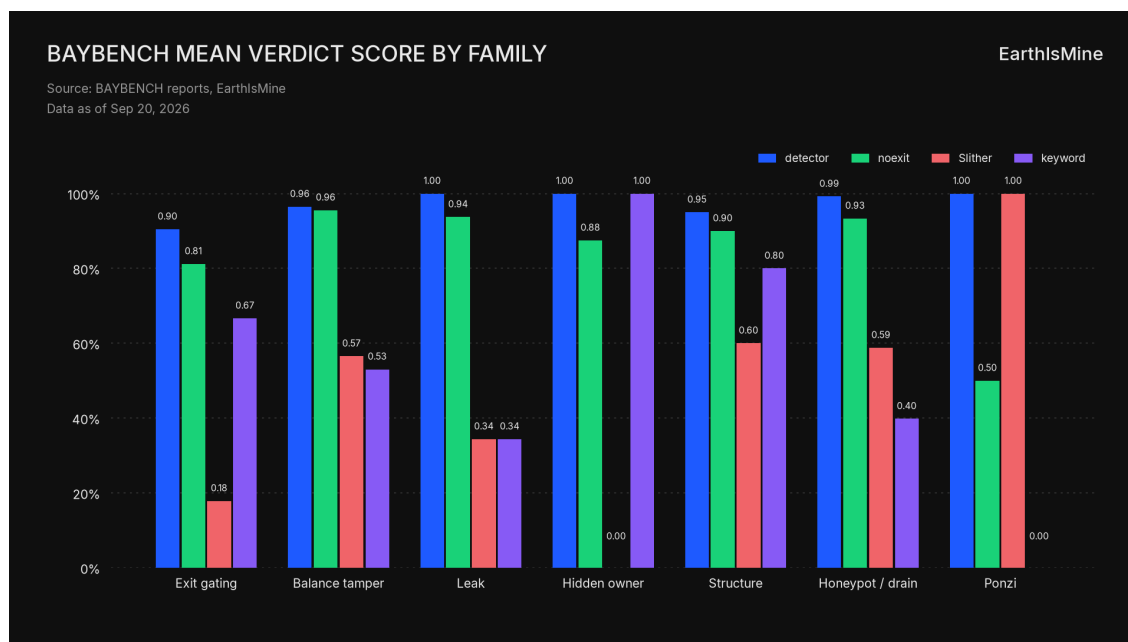


Figure 3: Mean verdict score by family. Detector Family F (honeypot / drain) is 0.9923 after decisive mode.

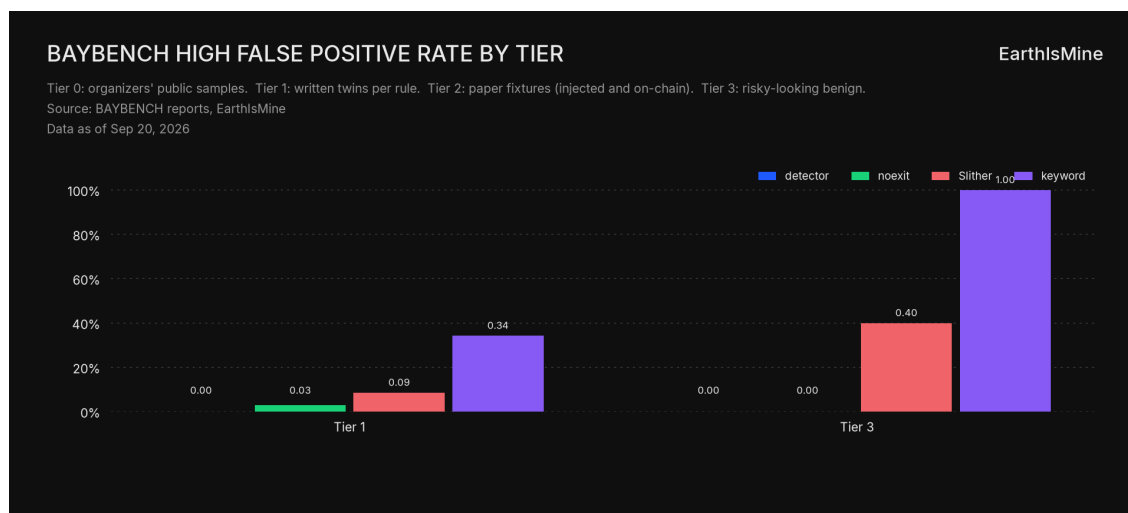


Figure 4: HIGH False Positive rate on Tier 1 and Tier 3. Detector is 0.0 on both.

5. Family recall is not a verdict, and extras are not False Positives

The detector appends every matching rule. On 551 labeled-malice cases it lists 3+ families on 312 (57%). Mean families fired 2.82; mean extra (not the paper tag) 1.89. 307 of those 312 are still Malicious. That is **over-attribution of findings**, not a False Positive verdict. HIGH-FP is the over-call brake, and it is 0.0.

The extras are often the same paper trick under this catalog's split, not "the paper missed that the contract is a scam." `HoneyBadger Withdraw() { require(msg.sender == Owner); }` is labeled F; we also fire C/D. `Pied-Piper destroy` is labeled B; we also fire C/D. Real compounds exist and are unlabeled. The iterate list (`docs/bench/misses.md`) only queues required-tag misses, so extras never enter it.

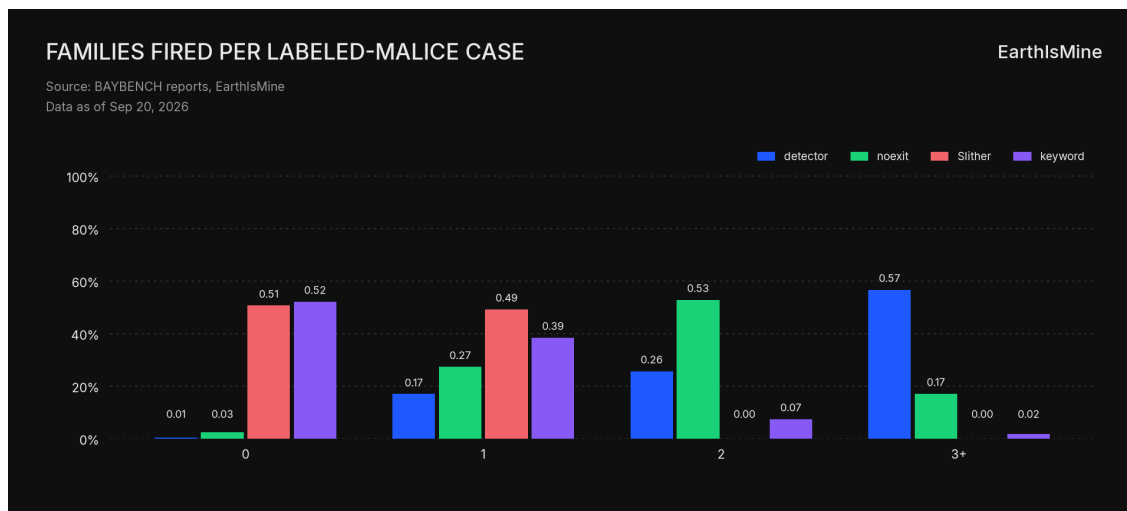


Figure 5: Families fired per labeled-malice case. Detector lists three or more families on 57% of those cases.

Mixing paper-tag recall with multi-pattern attribution makes 0.920 family recall look like “we listed every pattern.” This bench cannot say that. A later article should keep the two claims apart.

Family F after Phase 5

Under Phase 4, catalog F was MED and a single counting MED family became Uncertain(`med_findings`). On 106 F-labeled files the detector had already fired `HONEYPOT_LEGACY` and then abstained, while `noexit` called Malicious. That was a **policy split**, not a missing rule.

Phase 5 made `HONEYPOT_LEGACY` a counting finding. Detector F mean verdict is now 0.9923, family recall 0.9105 (n=324). `noexit` F mean 0.9336, family recall 0.5432. The “106 Uncertain after `HONEYPOT_LEGACY`” row belongs to the Phase 4 tree.

Bounding discriminators still force INFO. The five clean Tier 3 lookalikes must stay Benign with zero HIGH — detector does. USDC, Bancor, and MiniMe are preferred Malicious (accepted Benign), so a HIGH there is no longer a HIGH-FP.

6. Official public set

Ingested as Tier 0. Labels are the file comments. Both EarthIsMine tools are exact on all five under BAYBENCH scoring.

File	Gold	detector	noexit
P1_StandardToken	BENIGN	Benign exact	Benign exact
P2_HiddenMint	MALICIOUS	Malicious exact	Malicious exact
P3_Honeypot	MALICIOUS	Malicious exact	Malicious exact
P4_CappedMint	BENIGN	Benign exact (<code>constant_cap</code>)	Benign exact
P5_DelegatecallBackdoor	MALICIOUS	Malicious exact (<code>argument delegatecall</code>)	Malicious exact

P3 “Honeypot” is an **owner whitelist on transfer** (Family A), not a HoneyBadger bait-and-trap. The Family F debate does not apply.

P4 vs P2 is the cap: a hidden mint is MALICIOUS; a constant-bounded mint is BENIGN. Phase 4 left P4 as Uncertain(`med_findings`). The bounding discriminator now keeps it Benign.

P5 `execute(address target, bytes data) delegatecalls` a **calldata** target. Phase 4 required a privileged-writable *state* address and missed. The rule now fires when the owner can pick the target via argument.

Official grading is still a stdout JSON array (`run.sh` / submission mode), not this `results.json`. Tier 0 5/5 is the ingested public set under BAYBENCH labels.

7. Limits

- 190 detector compile fails (same count as the Docker report). Family recall on Tier 2 includes those Uncertain rows.
- Tier 2 has no `expected_rule_ids`. Per-rule charts are rule twins only.
- Slither family recall is near zero because High findings are not mapped onto A–G. That is a mapping gap, not a claim that Slither found no bugs.
- Runtime p50/p95 in the reports are wall times of the whole run, not per contract.
- Official Track 1 grades a stdout JSON array. This paper reports the bench format.
- A multi-label iterate environment (required vs observed families, a finer HoneyBadger map) is a later parent-spec amend. This paper does not drop DT or BB rows to match the current scores.

8. What this snapshot can say

The detector, on this mix, after decisive mode:

- Weighted 0.9714, Tier 0 exact 5/5, Tier 1 exact on the written twins, HIGH-FP 0.0.
- Family F is no longer parked at Uncertain. That lift is the verdict ladder, not a new HoneyBadger import from `noexit`.
- Extra family letters on already-Malicious labels are common and unscored. HIGH-FP, not family-count, is the over-call brake.
- Keyword matching and unmapped Slither High are weaker on the same 859 files, which is the track's stated preference for logic and permission structure over names.

What it cannot say: that 0.920 family recall listed every pattern in the source; that the private grade set will look like these five public files; or that official stdout scoring equals this `results.json` run.

The structural question in §1 is unchanged. The last mile is now a hard Benign or Malicious except where the analysis cannot see the other contract, the file does not compile, or the process times out.